

Circular 2025/03 — Mandatory Cybersecurity Controls and Incident Reporting Requirements

Reference:	FRA/CIR/2025/003	Issue Date:	10 March 2025
Effective Date:	01 July 2025	Response Deadline:	31 May 2025
Issuing Authority:	Financial Regulatory Authority	Classification:	MANDATORY

1. Introduction

The Authority has observed a significant increase in cyber incidents affecting regulated financial institutions, including ransomware attacks, data breaches, and Business Email Compromise (BEC) fraud. This circular mandates minimum cybersecurity controls and introduces a mandatory 4-hour incident notification requirement. All firms must achieve full compliance by 1 July 2025.

2. Mandatory Security Controls

With effect from 1 July 2025, all regulated firms must implement the following baseline security controls: (a) Multi-Factor Authentication (MFA) on ALL systems containing client data or financial records — no exceptions; (b) Encryption at rest (AES-256 minimum) for all data stores; (c) Encryption in transit (TLS 1.2 minimum, TLS 1.3 preferred) for all network communications; (d) Privileged Access Management (PAM) controls for all administrator accounts; (e) Continuous vulnerability scanning with critical patches applied within 24 hours.

3. Incident Notification Requirements

Firms must notify the Authority within FOUR (4) HOURS of becoming aware of any cybersecurity incident that: (a) Affects the confidentiality, integrity, or availability of client data; (b) Results in financial loss or potential financial loss to clients; (c) Disrupts critical business operations for more than 30 minutes; (d) Involves unauthorised access to systems. Initial notification may be made via telephone to the 24/7 Supervisory Hotline, followed by a written report within 24 hours using Form FRA-INC-001.

4. Third-Party and Supply Chain Risk

Firms must conduct annual cybersecurity assessments of all critical third-party technology providers. Assessment results must be retained and made available to the Authority upon request. Firms must ensure all technology contracts include mandatory breach notification clauses requiring vendors to notify the firm within 2 hours of any incident affecting the firm's data.

5. Deadline for Compliance Certification

By 31 May 2025, all Chief Information Security Officers (CISOs) must submit a Cybersecurity Compliance Attestation via the supervisory portal confirming that all mandatory controls have been implemented or providing a remediation plan with milestone dates for controls not yet in place. Firms without a designated CISO must appoint one by 31 March 2025.